Spear Phishing

What is Spear Phishing?

→ Spear Phishing is a **highly targeted** cyberattack where an adversary sends a **customized**, deceptive message to a specific individual or organization.

- Target is extensively researched
- Information is gathered from publicly available sources
- May impersonate leadership figures

Spear Phishing

A Real World Example:

SO REAL it happened within our organization!

Spear Phishing

From: [redacted] Robert <Robert[redacted].com>
Sent: Wednesday, March 27, 2024 7:25 AM
To: [redacted], Matt <Matt[redacted].com>
Subject: Possible security issue

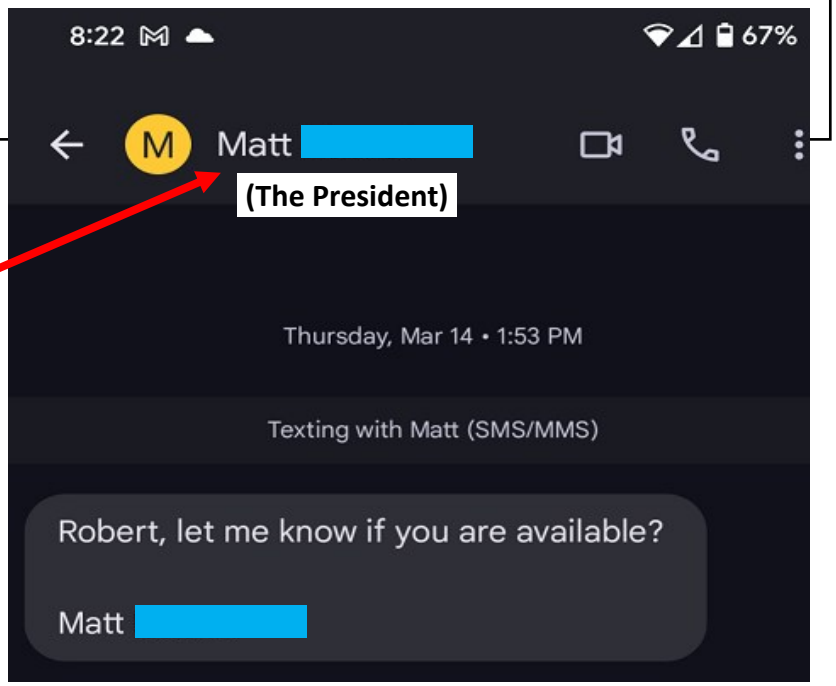
Hi Matt, I don't know if this happens often, but it looks like you may be being impersonated? The phone number traces back to central California.

Other than just being aware of it, it's nothing we can really control, I don't know that escalating it up through the IT chain will be of any use?

Robert [redacted]
Manufacturing Engineer

JTEKT Column Systems North America

Attached Text Msg



- May impersonate leadership figures
  - Exploits the sense of urgency authority demands
  - Fabricates pressure by coming via a personal communication line

Spear Phishing

Thus, IT is contacted!

From: [redacted] Matt <Matt[redacted].com>
Sent: Wednesday, March 27, 2024 8:41 AM
To: [redacted]; Slayden, Tim <Tim.Slayden[redacted].com>; [redacted]
Subject: FW: Possible security issue

Tim/[redacted],

Please see the email below from Robert. I know this happens all the time, but it's strange that they are able to target a brand-new employee and connect them to my name. I'm not sure if that is happening through our email system, Paylocity or somewhere else. Any ideas on what we should do with this? I know we've talked to Paylocity in the past.

Thanks
Matt

Spear Phishing

...And that's why you're here!

From: Slayden, Tim <Tim.Slayden[redacted].com>
Sent: Wednesday, March 27, 2024 12:00 PM
To: [redacted] <Matt[redacted].com>; [redacted]>; [redacted]>
Subject: RE: Possible security issue

There's probably very little we can do about these types of cyberattacks other than educate our employees to recognize they are fake and ignore them. This isn't exclusively a problem with any of our vendors leaking information. It's a problem resulting from the information our company and employees make public on the internet.

Your education is the **vital first defense** for our organization!

Spear Phishing

So how do they do it?

If I were to put my hacker hat on and attempt to Spear Phish JCSNA, here are the objectives I would want to accomplish:

A. **Find a list of employees to phish**
B. **Emulate a person of authority (the big fish drive a big phish)**
C. **Use available employee contact information to conduct the attack**

Reconnaissance is the first step an adversary takes to engineer a phishing lure

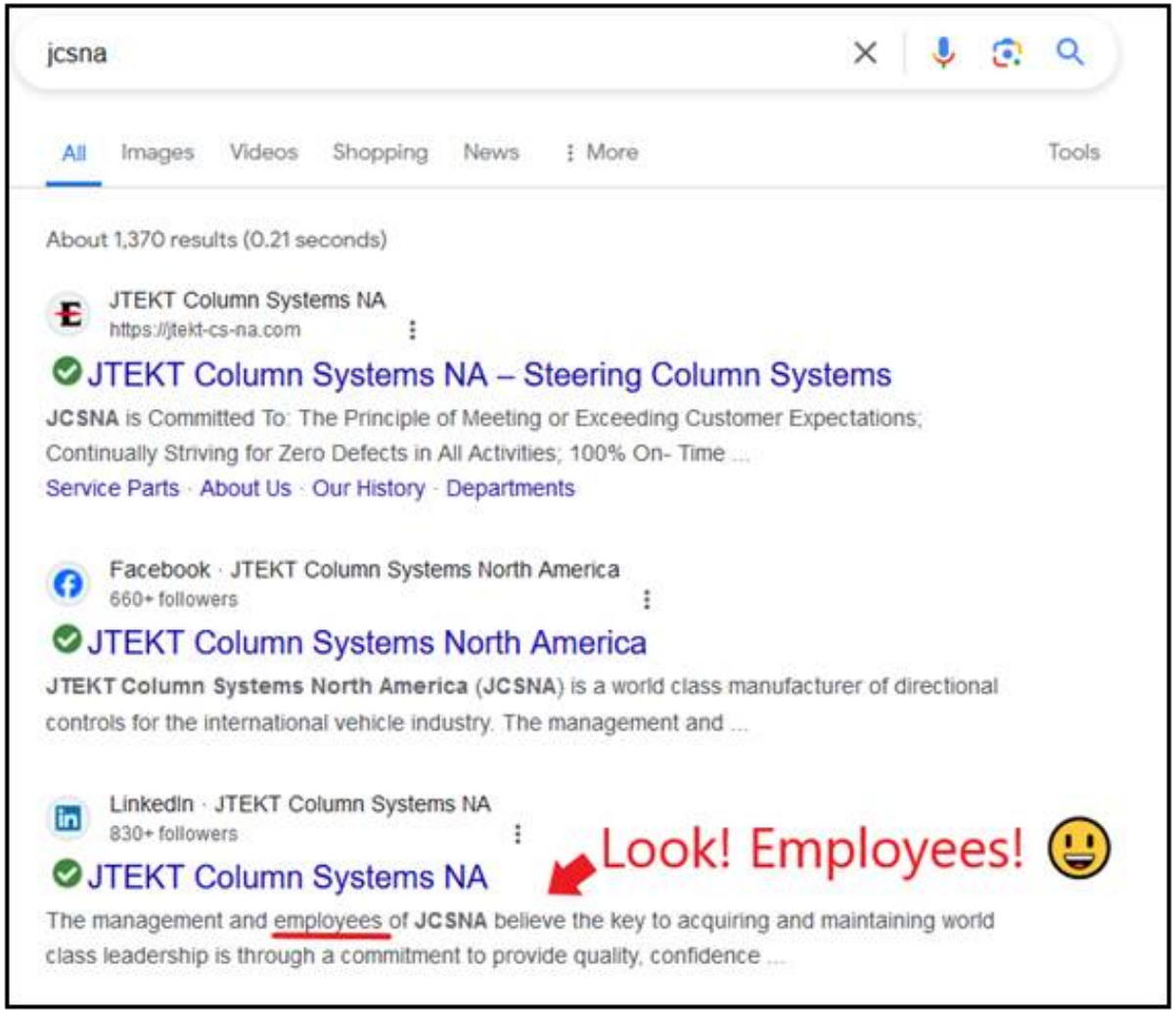
Objective A:
Find employees to phish

- Information is gathered from publicly available sources

  - Social networks like LinkedIn are gold mines to harvest public information

I don't know anything about the company except the name. Let's find some information –

1. Google JCSNA, see what comes up.



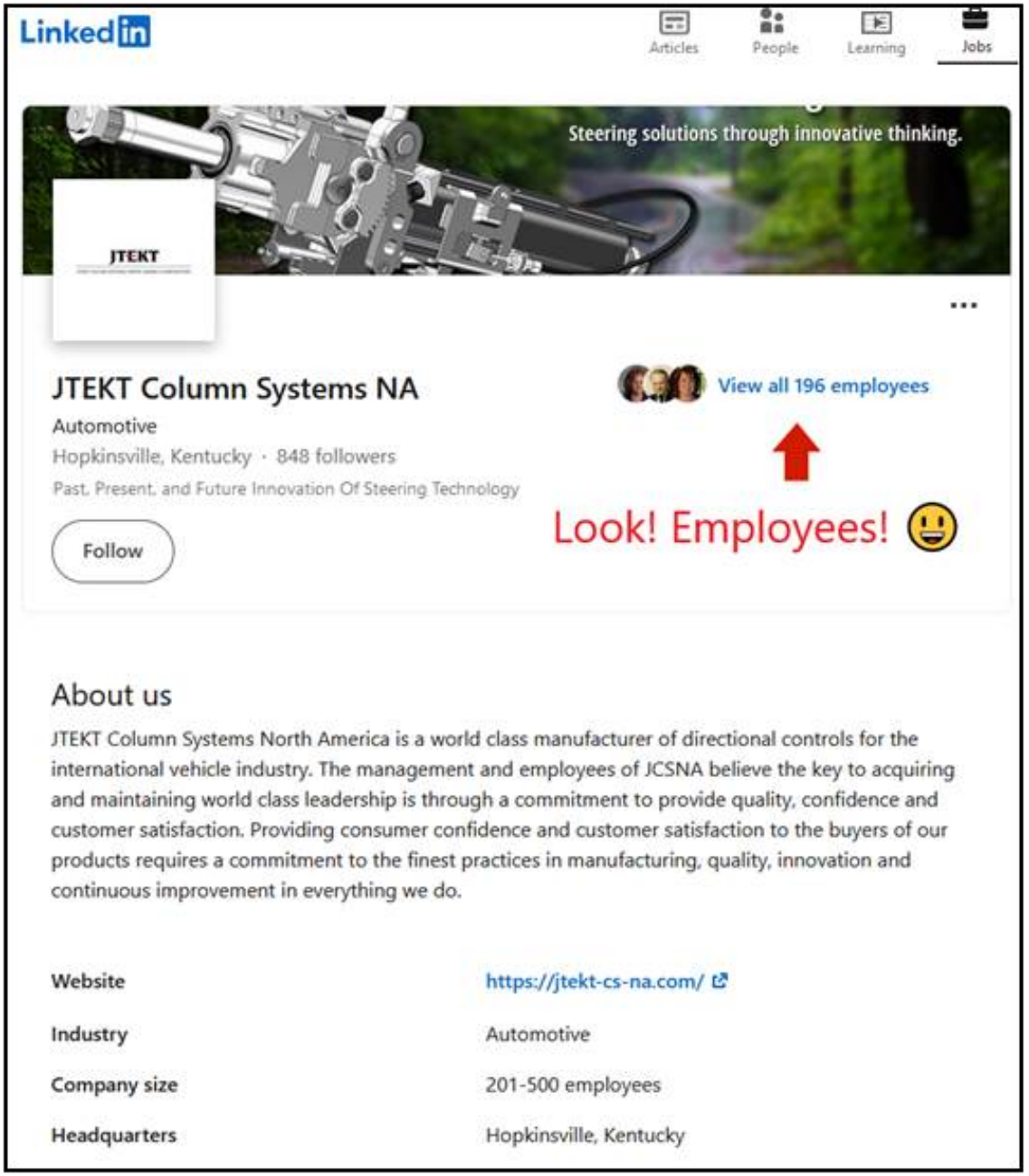
JCSNA has a company page on LinkedIn.

Cybersec Series

Objective A: ✓

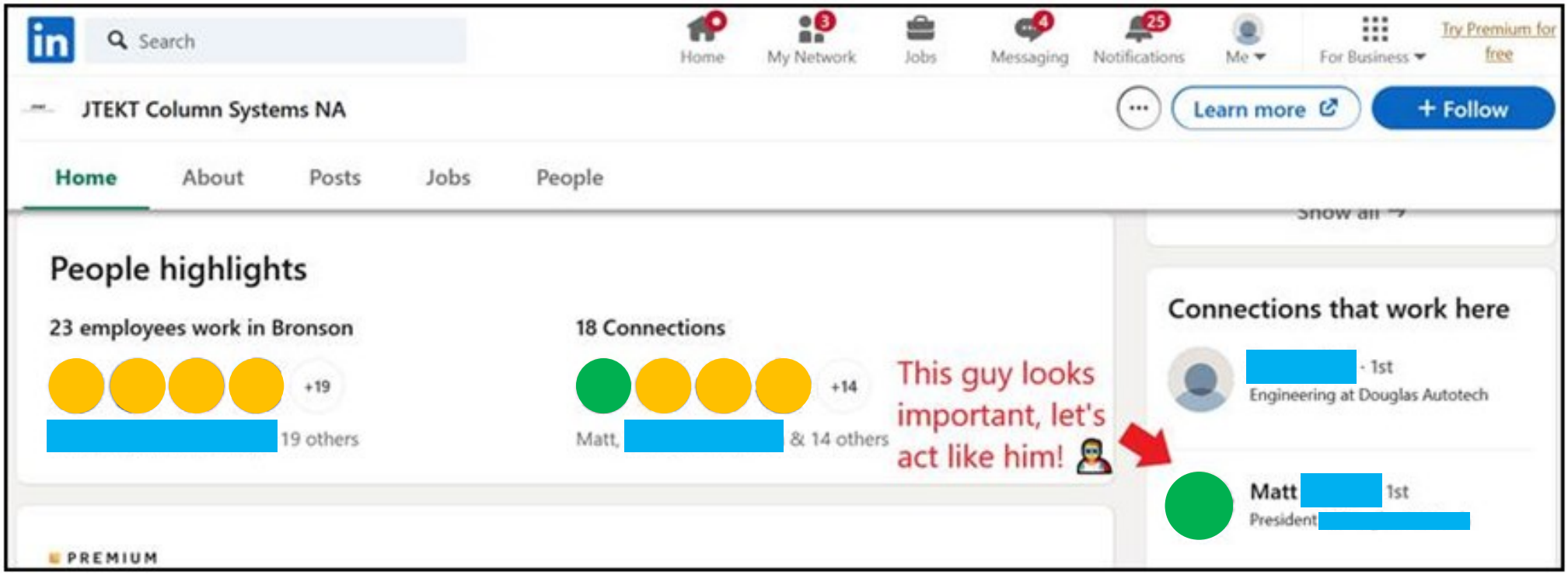
Find employees to phish

- Corporate Affiliation
- Public profiles (no privacy control)
- Personally Identifiable Information (PII)
- Job Role Exposure



Objective B: ✓
Emulate Authority

- Information is gathered from publicly available sources
- May impersonate leadership figures



A **President** will certainly command authority, and his full name is listed on the Home page!

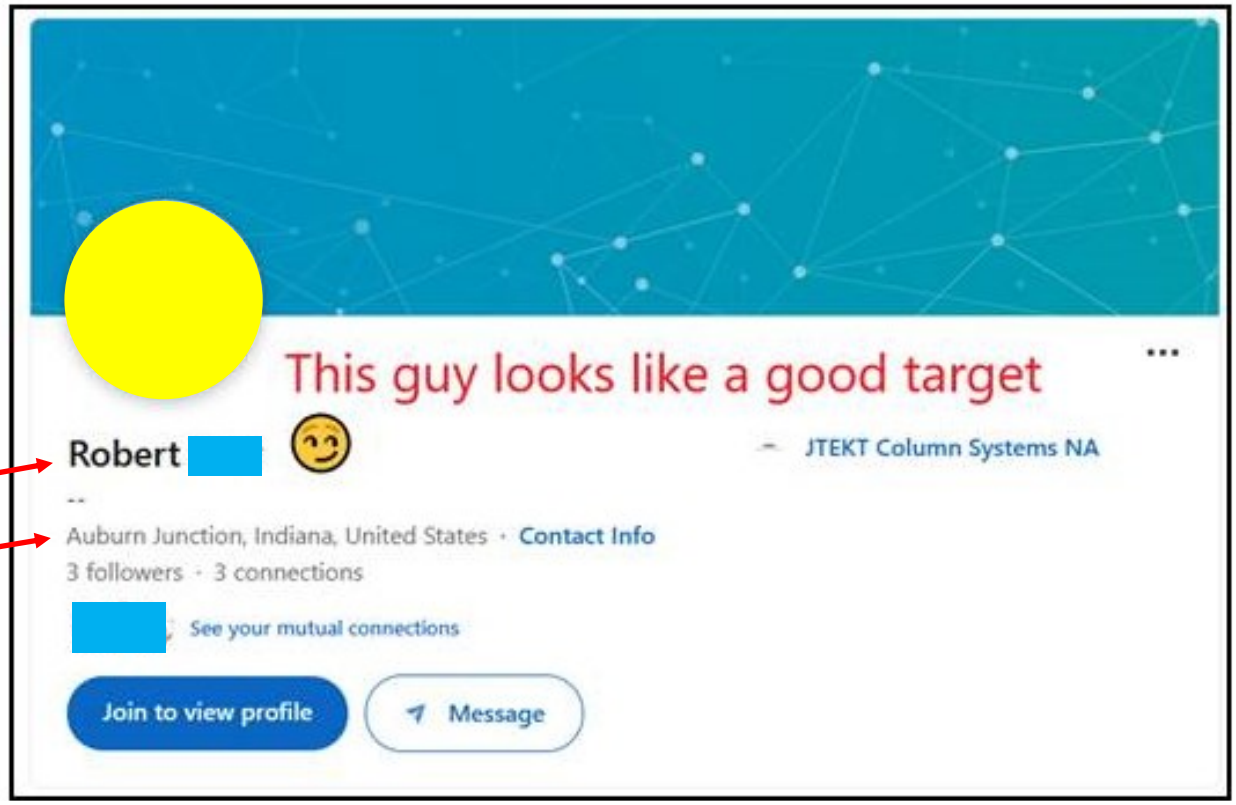
Objective C:
Gather Info for Attack

- Target is extensively researched
- Information is gathered from publicly available sources

No contact information is directly available

We DO, however, have some PII in the form of:

- A Full Name
- A Location

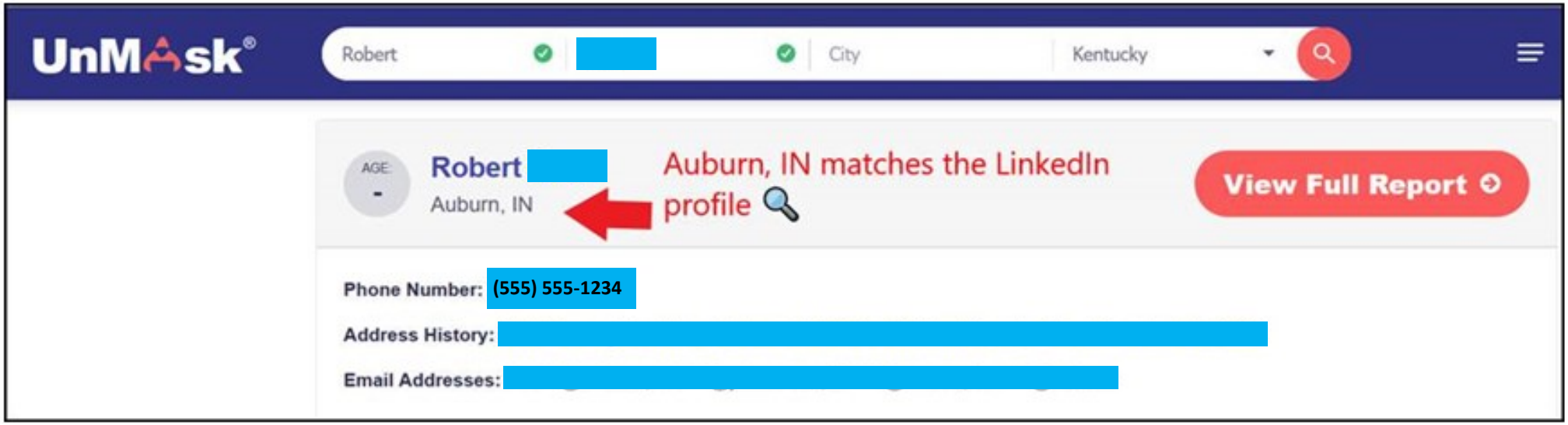


Objective C: ✓
Gather Info for Attack

- Target is extensively researched
- Information is gathered from publicly available sources

Return to Google once more!

And several sites later...



Success! Personal contact info found!

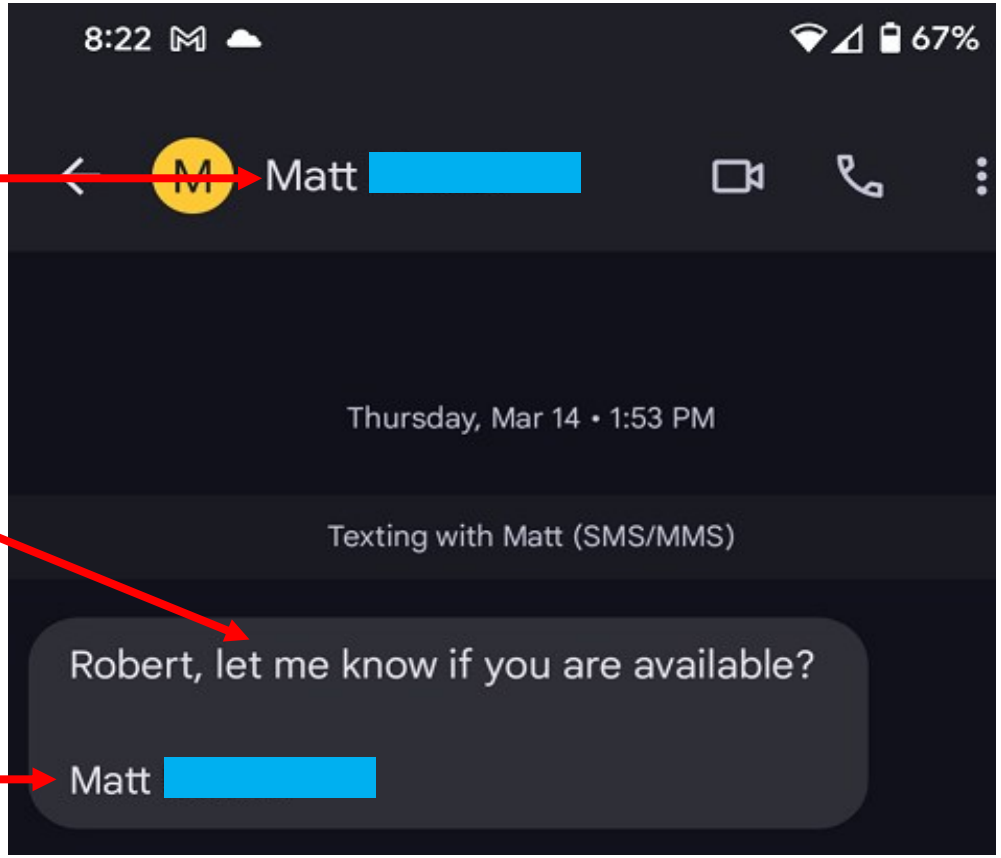
Putting it all together (Weaponization & Delivery)

- Target: Robert @ JCSNA
- Vector: Personal Phone #
- Technique: Impersonation

I set my name on my phone to Matt's full name so it appears as such on Robert's phone

Open with casual tone to bait conversation. More conversation calms the "security subconscious"

Sign with full name to reinforce the impersonation



Spear Phishing

How can I protect myself?

On the Internet	Communication Channels
Focus on:	Focus on:
Reconnaissance Mitigation	**Delivery** Verification

On the Internet

Use Privacy Controls

- Keep social media profiles Private or Friend's Only
- Use granular controls where available
- Enable strong Multi-Factor Authentication (MFA)

Avoid Oversharing PII

- If sharing info isn't important, DON'T!
- Pay attention to background details in public photos
- Delay posting travel details until *after* return

On the Internet

Corporate Sharing

- Avoid talking about internal technologies and tools
- Avoid revealing vendors
- Avoid externalizing company hierarchy

Communicate Concisely

- Keep auto replies generic
- Move detailed conversations to private channels
- Don’t share daily routines, habits, or project details

Communication Channels

Scrutinize Context

- Think about scope of responsibility
- Observe any unusual behavioral shifts
- Analyze the communication platform

Out-of-Band Verification

- Verify by questioning via separate medium
- Confirm contact info of sending party
- Use the internal contact directories when possible

Communication Channels

Question Urgency

- Recognize sudden pressure tactics
- Follow company standard procedures (SOP)
- Don't hesitate to escalate to management

Contact IT

- We're here to help you!
- Report anything suspicious
- PLEASE PLEASE PLEASE let us know what you have clicked or what information you shared

Final Message

RE: Possible security issue

HM [redacted] Matt

To Slayden, Tim; [redacted]; [redacted]

Reply

Thanks Tim. Very enlightening. Actually scary. Maybe we should start our own phishing enterprise (just kidding).

It's a shame we even have to worry about this kind of stuff.....

Let's keep educating our employees as you mentioned.

Thanks
Matt



You are now educated!